COMPTIA SECURITY+ SY0-701 DOMAIN 3 · SECURITY ARCHITECTURE (18%)

Security+ 3.1 · Cloud Infrastructures

Mestre CyberSec · **Lesson 3.1 — Cloud Infrastructures** (9:56) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Nuvem: IaaS (EC2 — tu cuida do SO pra cima); PaaS (heroku/AWS Beanstalk — plataforma pronta); SaaS (Gmail — tudo pronto). Serverless/FaaS (Lambda: código sobe na chamada, paga por execução). IaC (Infrastructure as Code — Terraform, CloudFormation — infra VERSÃO-EDITÁVEL). Defesa:

💡 Key Exam Highlights & Critical Concepts

- IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider
- Serverless (Lambda): sem servidor — paga execução
- IaC (Terraform): infra como código — versionada audível

🎯 Exam Tips & Typical CompTIA Scenarios

- 'cloud model where user manages the OS and above' = IaaS
- "runs code without managing servers" = serverless/FaaS

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 3.1 — Cloud Infrastructures)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Infrastructure as a Service (IaaS)

Cloud model where the provider supplies the underlying hardware, storage, and networking, but the customer is responsible for the operating system, middleware, runtime, data, and applications. EC2 is the canonical example.

⚠ ***Exam Trap:*** *Gatilho: 'user manages the OS and above' → IaaS. Se a questão mencionar controle do SO, patch do SO, ou instalação de hypervisor pelo cliente, é IaaS. Não confunda com PaaS.*

• Platform as a Service (PaaS)

Cloud model where the provider supplies the OS, middleware, and runtime platform; the customer only manages the application code and its data. Examples include Heroku and AWS Elastic Beanstalk.

⚠ ***Exam Trap:*** *Gatilho: 'customer only manages the application and data' → PaaS. Se a questão mostra desenvolvedores focando só em código sem se preocupar com servidor, é PaaS.*

• Software as a Service (SaaS)

Cloud model where the provider delivers a fully managed, ready-to-use application over the web; the customer only uses the software and configures user-level settings. Gmail and Microsoft 365 are classic examples.

⚠ ***Exam Trap:*** *Gatilho: 'provider manages everything, user just logs in' → SaaS. Se a questão fala em 'office suite', email corporativo ou CRM na nuvem, é SaaS.*

• Serverless / Function as a Service (FaaS)

Execution model in which the customer uploads individual functions that run on-demand in response to events; the underlying servers are entirely managed by the provider and billing is per execution. AWS Lambda is the prime example.

⚠ ***Exam Trap:*** *Gatilho: 'runs code without provisioning or managing servers' ou 'payments persist beyond execution' → Serverless/FaaS. Não confunda com IaaS (há servidor, você só não gerencia).*

• Infrastructure as Code (IaC)

Practice of defining and provisioning cloud resources through declarative or scripted configuration files, allowing infrastructure to be version-controlled, auditable, and reproducible. Terraform and AWS CloudFormation are the leading tools.

⚠️ ***Exam Trap:*** *Gatilho: 'versioned, auditable infrastructure' ou 'Terraform/CloudFormation' → IaC. A pegadinha é confundir com scripting tradicional: IaC é declarativo e idempotente.*

• Cloud Deployment Models (Public, Private, Hybrid, Community) (N/A)

Classification of cloud environments by ownership and access: Public (open to anyone, shared provider infrastructure), Private (dedicated to one organization), Hybrid (mix of on-prem + public cloud with orchestration), and Community (shared by organizations with a common concern, e.g., government or healthcare).

⚠️ ***Exam Trap:*** *Gatilhos: 'on-premises + cloud working together with orchestration' → Hybrid. 'Cloud shared by orgs with same regulatory requirement' → Community. Cuidado para não marcar Public quando a questão cita 'dedicated resources' (seria Private).*

• VM Escape

Security exploit in which an attacker breaks out of a virtualized guest OS and interacts directly with the hypervisor or other VMs on the same host, undermining the isolation that virtualization is supposed to provide.

⚠️ ***Exam Trap:*** *Gatilho: 'attacker breaks out of a virtual machine' ou 'attacks the hypervisor from a guest' → VM Escape. Sempre relacione com falha no isolamento de VMs; a defesa exige manter o hypervisor atualizado.*

• Containerization (N/A)

Lightweight virtualization technique that packages an application with its libraries and dependencies into an isolated user-space instance sharing the host OS kernel; Docker and Kubernetes (k8s) are the dominant technologies.

⚠️ ***Exam Trap:*** *Gatilho: 'lightweight isolation, shared kernel, faster than VMs' → Containers. Atenção na pegadinha: containers compartilham o kernel (diferente de VM, que tem SO completo), então um exploit no kernel afeta todos os contêineres.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Cloud Service Models: IaaS vs. PaaS vs. SaaS

🏠 **Real-World Analogy:** Think of dining options: IaaS is renting an unfurnished kitchen space where you must install the stove, run gas lines, and clean floors (you manage the OS, runtime, and patches). PaaS is renting a fully equipped commercial kitchen where utilities and appliances are maintained, so you only bring your ingredients and chef skills (you manage code and data only). SaaS is ordering takeout via delivery: a finished dish delivered ready-to-eat where you manage nothing behind the kitchen counter.

🔍 **Root Cause & Background:** The Shared Responsibility Model defines technical and legal culpability. In IaaS, breaches typically stem from the customer neglecting OS patching, insecure firewall groups, or poor bastion access; in SaaS, customer culpability centers almost exclusively on IAM misconfigurations and stolen credentials.

🛡️ **GRC Auditor Perspective:** Verify cloud shared responsibility matrices against contracts and SOC 2 Type II reports; enforce OS patching baselines and vulnerability scanning on IaaS VMs; audit SSO integration, tenant isolation, and MFA enforcement for all corporate SaaS platforms.

⚠️ **How CompTIA Tests This:** Trigger: 'customer is responsible for OS updates, patch management, and network firewall rules'. Answer: IaaS (Infrastructure as a Service). If 'customer only manages application code and data while provider manages OS and runtime', choose PaaS.

📌 Serverless Computing / FaaS (Function as a Service)

🏠 **Real-World Analogy:** Imagine a motion-activated hallway light. It doesn't run continuously burning expensive electricity; the split second someone walks past (an event trigger), it turns on for 10 seconds, accomplishes its job, and shuts down completely. You only pay for the precise seconds the bulb was lit.

🔍 **Root Cause & Background:** Traditional servers sit idle consuming operating budget while maintaining persistent attack surfaces. Serverless executes stateless ephemeral micro-functions triggered by events. However, overly permissive IAM execution roles attached to functions can allow attackers to hijack cloud storage and databases.

🛡️ **GRC Auditor Perspective:** Audit IAM execution roles bound to serverless functions for strict least privilege; verify function execution timeouts and concurrency throttling to prevent Economic Denial of Sustainability (EDoS) budget exhaustion.

⚠️ **How CompTIA Tests This:** Trigger: 'executes microservice code only in response to events or HTTP requests, with no underlying server to manage or patch'. Answer: Serverless / FaaS (Function as a Service).

📌 Cloud Deployment Models: Public, Private, Community, and Hybrid

🏠 **Real-World Analogy:** Public cloud is an apartment building open to anyone where tenants share physical elevators while locking their private units. Private cloud is a single-family gated estate with complete physical exclusivity. Community cloud is a cooperative medical village shared only by partner hospitals with common regulatory mandates. Hybrid cloud is maintaining your primary secure home while renting serviced corporate apartments during peak seasonal demands.

🔍 **Root Cause & Background:** Balancing operational agility and economics against stringent regulatory compliance mandates. Organizations store classified data in private or on-premises infrastructure while bursting transient public-facing workloads into public cloud environments (cloud bursting).

🛡️ **GRC Auditor Perspective:** Evaluate data sovereignty covenants and multi-tenant isolation controls; verify third-party attestations (FedRAMP, SOC 2 Type II, ISO 27017) and audit boundary controls connecting hybrid cloud tiers.

⚠️ **How CompTIA Tests This:** Trigger: 'several hospitals share cloud infrastructure to comply with health regulations and split maintenance costs'. Answer: Community Cloud. 'Organization connects on-premises data center with public cloud provider' -> Hybrid Cloud.

📌 Edge Computing vs. Fog Computing

🏠 **Real-World Analogy:** Think of an autonomous vehicle approaching a sudden obstacle: it cannot upload camera feeds to a cloud datacenter 1,000 miles away and wait 80 milliseconds for braking instructions—it would crash. Real-time braking logic processed directly on the onboard sensor chip is Edge Computing. Fog Computing is the local roadside 5G pole or regional gateway aggregating telemetry from 50 neighborhood vehicles to optimize traffic light sequences before relaying batch metrics to the core cloud.

🔍 **Root Cause & Background:** Physical latency and upstream bandwidth constraints prohibit round-trip transmission for time-critical telemetry (industrial robotics, smart grid, medical implants). Processing locally eliminates latency and minimizes WAN saturation.

🛡️ **GRC Auditor Perspective:** Assess physical tamper-resistance and zero-trust authentication on deployed edge gateways; mandate full-disk encryption (FDE) for local caches and mutual TLS (mTLS) for upstream fog-to-cloud telemetry sync.

⚠️ **How CompTIA Tests This:** Trigger: 'autonomous sensors require ultra-low latency processing directly at the point of data generation to eliminate network lag'. Answer: Edge Computing. 'Intermediary processing layer between local IoT sensors and central cloud' -> Fog Computing.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Customer must manage operating system patches, antivirus, and security group firewall rules on leased virtual machines	**IaaS (Infrastructure as a Service)**
Developers deploy application code without provisioning or managing underlying operating systems or runtime servers	**PaaS (Platform as a Service)**
Employees consume ready-to-use email and office productivity apps via web browser with zero server maintenance	**SaaS (Software as a Service)**
Event-driven code execution with no persistent host instances, billed strictly by millisecond execution duration	**Serverless / FaaS (Function as a Service)**
Multiple healthcare entities pool shared infrastructure to split costs and adhere to uniform regulatory standards	**Community Cloud**
Real-time computational processing executed directly on endpoint sensors to eliminate transmission delay to central cloud	**Edge Computing**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A company rents virtual machines, block storage, and virtual networking from a public cloud provider. The provider manages the physical hosts and hypervisor, while the company's administrators are responsible for patching the guest operating systems, installing middleware, and configuring security groups. Which cloud service model does this describe?

A) IaaS

B) PaaS

C) SaaS

D) FaaS

QUESTION 2 · EXAM SCENARIO

A development team wants to deploy a Java web application without managing the operating system, runtime updates, or load balancing. The provider supplies the runtime, middleware, and scaling, but the team remains responsible for application code and configuration. Which model is being used?

A) IaaS

B) PaaS

C) SaaS

D) Serverless/FaaS

QUESTION 3 · EXAM SCENARIO

An organization adopts a cloud-based email and office productivity suite. The provider manages the data centers, application updates, and service availability, while the organization only manages user accounts, access permissions, and its own data. Which cloud service model is in use?

A) IaaS

B) PaaS

C) SaaS

D) FaaS

QUESTION 4 · EXAM SCENARIO

A startup uploads image-processing code that runs only when new photos are added to object storage. The cloud provider provisions the runtime on demand, scales automatically per event, and bills based on execution time and requests. The startup does not manage servers or containers. Which model best matches this deployment?

A) IaaS

B) PaaS

C) SaaS

D) Serverless/FaaS

QUESTION 5 · EXAM SCENARIO

A cloud engineering team stores Terraform definitions in a Git repository and deploys them through a CI/CD pipeline. During a review, an auditor finds a commit that defines a production storage bucket with public read access. Which control would most effectively prevent similar insecure infrastructure definitions from reaching production?

A) Run automated IaC static analysis and policy-as-code checks in the CI/CD pipeline.

B) Require multi-factor authentication for the cloud root account.

C) Enable default encryption on all storage buckets.

D) Deploy a bastion host for administrative SSH access.

QUESTION 6 · EXAM SCENARIO

Several hospitals with similar regulatory requirements form a consortium to share a cloud environment for a common patient-records application. The infrastructure is provisioned for the consortium's exclusive use and governed by the participating organizations, not the general public. Which deployment model is this?

A) Public cloud

B) Private cloud

C) Hybrid cloud

D) Community cloud

QUESTION 7 · EXAM SCENARIO

A retailer keeps payment processing systems in its own data center for compliance but uses a public cloud for its e-commerce web front end and seasonal analytics. The two environments are connected by a secure VPN and share centralized identity management. Which cloud deployment model is described?

A) Public

B) Private

C) Hybrid

D) Community

QUESTION 8 · EXAM SCENARIO

An attacker compromises a guest virtual machine in a multi-tenant cloud environment and then exploits a hypervisor vulnerability to read memory and access other customers' VMs running on the same physical host. What is this attack called?

A) Container escape

B) VM escape

C) Cloud data exfiltration

D) Hypervisor denial of service

QUESTION 9 · EXAM SCENARIO

A company runs microservices in containers on a shared Kubernetes cluster. After a vulnerable web application is compromised inside a container, the attacker attempts to break out and affect the underlying node and other workloads. Which control most directly reduces the impact of this type of attack?

A) Run containers as non-root, drop unnecessary Linux capabilities, and enforce seccomp/AppArmor profiles.

B) Enable a web application firewall in front of the ingress controller.

C) Encrypt persistent volumes with a customer-managed key.

D) Move the cluster to a single-tenant private cloud without changing container configurations.

QUESTION 10 · EXAM SCENARIO

A company subscribes to a SaaS customer relationship management platform. The provider is responsible for the application code, servers, and physical data center security. Which security responsibility remains primarily with the customer?

A) Patching the CRM application's server operating systems

B) Maintaining the hypervisor that hosts the CRM application

C) Configuring user access, roles, and multi-factor authentication

D) Securing the physical perimeter of the provider's data center

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — IaaS

IaaS provides virtualized compute, storage, and networking. The customer manages the guest OS, middleware, applications, and some security controls, while the provider manages the physical infrastructure and hypervisor. PaaS would hide OS and runtime management; SaaS would provide a complete application; FaaS would run event-driven code without server management.

Question 2: Option B — PaaS

PaaS provides a managed platform for deploying applications. The provider manages the OS, runtime, middleware, and scaling, while the customer manages the application code and configuration. IaaS would require OS management; SaaS is a complete application; FaaS is typically event-driven function execution rather than a managed application platform.

Question 3: Option C — SaaS

SaaS delivers a complete application managed by the provider. The customer does not manage the underlying servers, OS, runtime, or application code, but remains responsible for identity, access control, data handling, and configuration of user permissions.

Question 4: Option D — Serverless/FaaS

Serverless/FaaS executes code in response to events without requiring the customer to manage servers or containers. The provider handles provisioning, scaling, and runtime availability, and billing is typically based on invocations and execution duration. IaaS and PaaS require more infrastructure or platform management by the customer, while SaaS is a complete application.

Question 5: Option A — Run automated IaC static analysis and policy-as-code checks in the CI/CD pipeline.

Infrastructure as Code should be validated before deployment. Static analysis and policy-as-code checks can detect insecure Terraform definitions, such as public storage buckets, and block them in the CI/CD pipeline. MFA protects accounts but does not prevent misconfigured IaC. Encryption does not stop public exposure, and a bastion host is unrelated to storage bucket permissions.

Question 6: Option D — Community cloud

A community cloud is shared by multiple organizations with common interests, compliance needs, or missions. It is not open to the general public like a public cloud, not dedicated to a single organization like a private cloud, and not a mix of on-premises and public cloud like a hybrid cloud.

Question 7: Option C — Hybrid

A hybrid cloud combines private or on-premises infrastructure with public cloud services. The retailer keeps sensitive payment systems on-premises while using public cloud for other workloads, integrating them with secure connectivity and centralized identity.

Question 8: Option B — VM escape

A VM escape occurs when an attacker breaks out of a guest virtual machine and compromises the hypervisor or other VMs on the same host. Container escape applies to containers rather than hypervisors, data exfiltration is a possible impact, and denial of service does not describe accessing other VMs.

Question 9: Option A — Run containers as non-root, drop unnecessary Linux capabilities, and enforce seccomp/AppArmor profiles.

Container hardening reduces the ability to escape or affect the host. Running as non-root, dropping capabilities, and enforcing seccomp/AppArmor profiles limit the privileges available after compromise. A WAF may block some web attacks but does not directly prevent container breakout. Encryption protects data at rest, and a private cloud alone does not fix insecure container configurations.

Question 10: Option C — Configuring user access, roles, and multi-factor authentication

In SaaS, the provider manages the application, operating systems, servers, hypervisor, and physical infrastructure. The customer remains responsible for managing users, access permissions, roles, authentication settings such as MFA, and the data it places in the service.